

Botium Toys: Informe de alcance, objetivos y evaluación de riesgos

Auditoría interna de seguridad, inventario de activos y análisis de cumplimiento

Alcance y objetivos de la auditoría

Alcance: El alcance se define como la totalidad del programa de seguridad de Botium Toys. Esto implica evaluar todos los activos junto con los procesos y procedimientos internos relacionados con la implementación de controles y las mejores prácticas de cumplimiento normativo.

Objetivos: Evaluar los activos existentes y completar la lista de verificación de controles y cumplimiento para determinar qué controles y mejores prácticas deben implementarse a fin de mejorar la postura de seguridad de Botium Toys.

Activos actuales

Los activos gestionados por el Departamento de TI incluyen:

- Equipos locales e instalaciones para las necesidades operativas de la oficina.
- Equipamiento de los empleados: dispositivos de usuario final (ordenadores de sobremesa/portátiles, smartphones), estaciones de trabajo remotas, auriculares, cables, teclados, ratones, estaciones de acoplamiento (docking stations), cámaras de vigilancia, etc.
- Productos de tienda física disponibles para venta minorista presencial y online; almacenados en el almacén anexo de la empresa.
- Gestión de sistemas, software y servicios: contabilidad, telecomunicaciones, bases de datos, seguridad, comercio electrónico (e-commerce) y gestión de inventario.
- Acceso a Internet.
- Red interna.
- Retención y almacenamiento de datos.
- Mantenimiento de sistemas heredados (legacy): sistemas al final de su vida útil (End-of-Life) que requieren supervisión humana.

Evaluación de riesgos

Descripción del riesgo

Actualmente, existe una gestión inadecuada de los activos. Además, Botium Toys no cuenta con todos los controles adecuados implementados y es posible que no cumpla plenamente con las normativas y estándares estadounidenses e internacionales.

Mejores prácticas de control

La primera de las cinco funciones del marco NIST CSF es Identificar (Identify). Botium Toys deberá dedicar recursos a identificar sus activos para gestionarlos adecuadamente. Asimismo, necesitarán clasificar los activos existentes y determinar el impacto que tendría la pérdida de dichos activos, incluidos los sistemas, en la continuidad del negocio.

Puntuación de riesgo

Puntuación de riesgo: 8 / 10 (Alta)

En una escala del 1 al 10, la puntuación de riesgo es de 8, lo cual se considera bastante alto. Esto se debe a la falta de controles y al incumplimiento de las mejores prácticas normativas y de conformidad.

Comentarios adicionales

El impacto potencial por la pérdida de un activo está calificado como medio, debido a que el departamento de TI desconoce cuáles activos estarían en riesgo. El riesgo para los activos o la imposición de multas por parte de organismos reguladores es alto, debido a que Botium Toys no cuenta con todos los controles necesarios ni sigue plenamente las mejores prácticas vinculadas a regulaciones de cumplimiento para mantener los datos críticos privados y seguros. Revise los siguientes puntos para conocer los detalles específicos:

- Actualmente, todos los empleados de Botium Toys tienen acceso a los datos almacenados internamente y podrían acceder a los datos de los titulares de tarjetas y a la información de identificación personal (PII / SPII) de los clientes.
- En la actualidad no se utiliza cifrado para garantizar la confidencialidad de la información de las tarjetas de crédito de los clientes que es aceptada, procesada, transmitida y almacenada localmente en la base de datos interna de la empresa.
- No se han implementado controles de acceso relativos al mínimo privilegio ni a la separación de funciones.
- El departamento de TI ha asegurado la disponibilidad e integrado controles para garantizar la integridad de los datos.
- El departamento de TI dispone de un cortafuegos (firewall) que bloquea el tráfico basándose en un conjunto de reglas de seguridad debidamente definidas.
- El software antivirus está instalado y es supervisado periódicamente por el departamento de TI.
- El departamento de TI no ha instalado un sistema de detección de intrusiones (IDS).
- Actualmente no existen planes de recuperación ante desastres y la empresa no dispone de copias de seguridad (backups) de los datos críticos.
- El departamento de TI ha establecido un plan para notificar a los clientes de la Unión Europea en un plazo máximo de 72 horas si se produce una brecha de seguridad. Además, se han desarrollado y aplicado políticas, procedimientos y procesos de privacidad entre los miembros del departamento de TI y otros empleados para documentar y mantener los datos adecuadamente.

- Aunque existe una política de contraseñas, sus requisitos son nominales y no se ajustan a los requisitos mínimos actuales de complejidad (por ejemplo, al menos ocho caracteres, combinación de letras, al menos un número y caracteres especiales).
- No existe un sistema centralizado de gestión de contraseñas que haga cumplir los requisitos mínimos de la política, lo que en ocasiones afecta a la productividad cuando los empleados o proveedores envían un ticket a TI para recuperar o restablecer una contraseña.
- Aunque los sistemas heredados (legacy) se supervisan y mantienen, no existe un calendario regular establecido para estas tareas y los métodos de intervención no están claros.
- La ubicación física de la tienda, que incluye las oficinas principales de Botium Toys, el local comercial y el almacén de productos, cuenta con cerraduras suficientes, videovigilancia actualizada por circuito cerrado de televisión (CCTV) y sistemas funcionales de detección y extinción de incendios.